

IkonPay Key Compromise Protocol (KCP)

Document ID: IP-KCP-01 v1.0

Classification: CONFIDENTIAL

Owner: CISO (Dave)

Effective Date: 10/02/2026

Review Cycle: Annual (or upon any material change to people, processes, or technology)

CCSS v9 Requirements: 2.04.1.1, 2.04.1.2, 2.04.2.1

TABLE OF CONTENTS

IkonPay Key Compromise Protocol (KCP)	1
1. PURPOSE	2
2. KEY MATERIAL INVENTORY SUMMARY	3
Peripheral Key Material	4
3. KCP TRIGGER EVENTS	5
3.1 Confirmed Triggers	5
3.2 Assessed Triggers	6
4. ROLES AND RESPONSIBILITIES	7
Role Activation Matrix	8
5. APPROVED COMMUNICATION CHANNELS	9
Channels Explicitly NOT Approved for KCP	9
Identity Verification Protocol	9
6.1 Response Track A: Hot Wallet Key Compromise	10
Detection Phase	10
Eradication Phase	11
Recovery Phase	11
Post-Incident	12
6.2 Response Track B: Warm Wallet — Single Key Share Compromise	12
Detection Phase	12
Containment Phase	12
Eradication Phase	13
Recovery Phase	13
6.3 Response Track C: Cold Wallet — Single Key Share Compromise	14
6.4 Response Track D: Multisig Threshold Breach — At/Above Signing Threshold	14
6.5 Response Track E: CloudHSM Logical Compromise	15
6.6 Response Track F: Operator Compromise	15
7. RESCUE WALLET ADDRESSES	17
8. ESCALATION TIMELINES	18
9. POST INCIDENT REQUIREMENTS	19
9.1 After-Action Report (AAR)	19
9.2 KCP Updates	19
9.3 Evidence Preservation	19
10. TESTING AND REHERSAL SCHEDULE	20
12. DISTRIBUTION LIST	20

1. PURPOSE

This Key Compromise Protocol (KCP) defines IkonPay's mandatory response procedures when key material is known or suspected to be compromised. It establishes:

- **What** constitutes a KCP trigger event
- **Who** is responsible for each phase of the response
- **How** the response is executed, per key material classification
- **When** escalation, communication, and notification occur
- **Where** backup and recovery resources are located

The KCP covers all key material within the CCSS Trusted Environment, including the hot wallet (CloudHSM single-signer), warm wallet (2-of-3 multisig), and cold wallet (2-of-3 multisig).

2. KEY MATERIAL INVENTORY SUMMARY

Full inventory including backups maintained in IP-INV-05 v3.0. This section provides a classification summary for KCP purposes.

ID	Classification	Type	Storage Location	Signing Config	Compromise Urgency
KM-HOT-BTC-01	Hot wallet BTC signing key	HSM-resident	AWS CloudHSM (PROD-CUSTODY VPC)	Single-signer, automated	CRITICAL — minutes
KM-HOT-EVM-01	Hot wallet EVM signing key (hot_evm_signing_prod_01)	HSM-resident	AWS CloudHSM (PROD-CUSTODY VPC)	Single-signer, automated	CRITICAL — minutes
KM-WARM-01	Warm wallet key share #1	Hardware wallet (Ledger Nano X)	Treasury Operator A (Bob) — Pune Office	2-of-3 multisig	HIGH — hours
KM-WARM-02	Warm wallet key share #2	Hardware wallet (Ledger Nano X)	Treasury Operator B (Ken) — Pune Office	2-of-3 multisig	HIGH — hours

KM-WARM-03	Warm wallet key share #3	Hardware wallet (Ledger Nano X)	Security Officer (Carol) — Pune Office	2-of-3 multisig	HIGH — hours
KM-COLD-01	Cold wallet key share #1	Hardware wallet (Ledger Nano X)	Co-Founder 1 (John) — Pune Office	2-of-3 multisig	HIGH — hours
KM-COLD-02	Cold wallet key share #2	Hardware wallet (Ledger Nano X)	Co-Founder 2 (Doe) — Pune Office	2-of-3 multisig	HIGH — hours
KM-COLD-03	Cold wallet key share #3	Hardware wallet (Ledger Nano X)	Co-Founder 3 (Alice) — Pune Office / Bank Locker	2-of-3 multisig	HIGH — hours

Peripheral Key Material

ID	Classification	Description	Compromise Impact
KM-HSM-API	HSM API credentials / IAM keys	Service principal <code>svc-signer-prod</code>	Unauthorized signing requests
KM-XPUB-WARM	BTC warm wallet xpubs	Deposit address derivation	Privacy leak (not fund loss)
KM-XPUB-COLD	BTC cold wallet xpubs	Deposit address derivation	Privacy leak (not fund loss)

3. KCP TRIGGER EVENTS

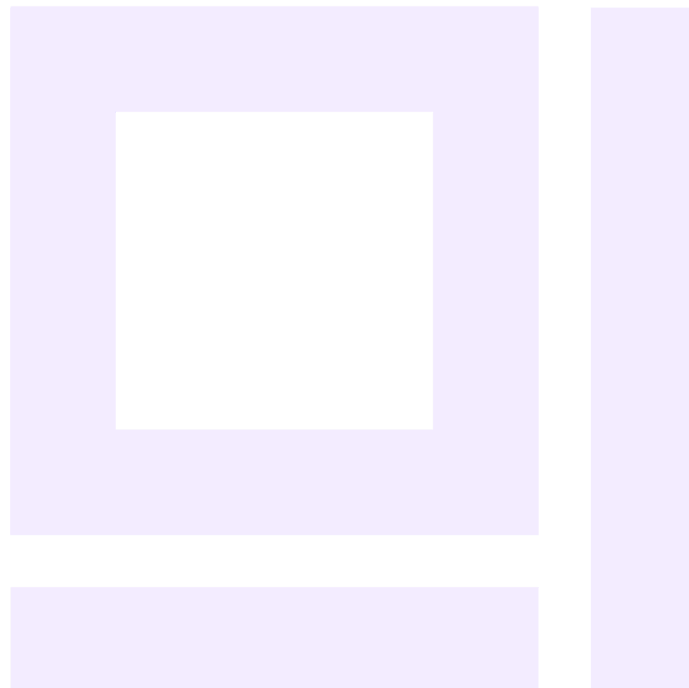
The following events **mandate** invocation of this KCP. Any team member who identifies a trigger event is **required** to escalate immediately.

3.1 Confirmed Triggers (Immediate KCP Invocation)

Trigger ID	Event	Affected Classification	Response Track
T-01	Unauthorized on-chain transaction from any IkonPay wallet	Hot / Warm / Cold	Emergency — per classification
T-02	Detection of unauthorized API access to CloudHSM or Signer Service	Hot wallet	Emergency — Hot Wallet
T-03	Hardware wallet device reported lost, stolen, or physically tampered	Warm / Cold	Controlled — per classification
T-04	Tamper-evident seal broken on backup storage media	Warm / Cold	Controlled — Backup Compromise
T-05	Signer reports device compromise (malware, phishing, physical theft)	Warm / Cold	Controlled or Emergency based on scope
T-06	Operator believed compromised (disappearance, duress indicators)	Warm / Cold	Emergency — Operator Compromise
T-07	Vendor security advisory affecting CloudHSM or Ledger firmware	Hot / Warm / Cold	Assessed — Vendor Response
T-08	Credible external threat intelligence naming IkonPay systems	All	Assessed — Threat Intelligence
T-09	Anomalous signer behaviour detected (unusual signing patterns, off-hours activity)	Warm / Cold	Assessed — Insider Threat

3.2 Assessed Triggers (Investigation Required Before Full KCP)

Trigger ID	Event	Initial Action
T-10	Unverified rumour or social media claim of IkonPay compromise	CISO assessment within 30 minutes
T-11	CloudWatch or monitoring anomaly below alert threshold	On-call engineer investigation within 15 minutes
T-12	Third-party service provider reports a breach.	Security Officer assessment within 2 hours



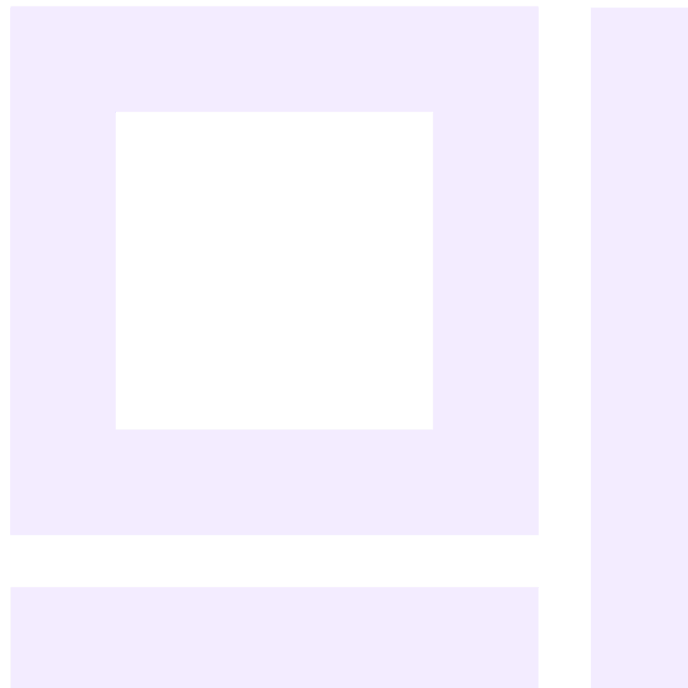
4. ROLES AND RESPONSIBILITIES

Roles are defined by function, not by name, per CCSS v9 Req 2.04.1.2.

Role	Primary Actor	Secondary Actor	KCP Authority
Incident Commander (IC)	CISO	Co-Founder 1	Full decision authority during KCP execution. Authorises emergency fund movements, external communications, and law enforcement contact.
On-Call Engineer	Sr. Platform Engineer	Sr. DevOps Engineer	First responder. Authority to halt Signer Service without IC approval. Performs initial triage.
Warm Wallet Signers	Treasury Operator A, Treasury Operator B, Security Officer	Any 2 of the 3 warm signers can execute a 2-of-3 sweep.	Execute emergency warm wallet sweep to rescue address when authorised by IC.
Cold Wallet Signers	Co-Founder 1, Co-Founder 2, Co-Founder 3	Any 2 of the 3 cold signers can execute a 2-of-3 sweep.	Execute emergency cold wallet sweep to rescue address when authorised by IC.
Communications Lead	Compliance Manager	CISO	Manages external notifications (customers, regulators, media). No public statement without IC approval.
Legal Counsel	Sr. Associate: External Legal team	Sr. Associate: In-house counsel	Advises on regulatory notification timing, evidence preservation, law enforcement coordination.
Forensic Lead	Security Officer	Sr. Platform Engineer	Leads technical investigation. Preserves evidence. Determines root cause and blast radius.

Role Activation Matrix

Severity	Who is notified immediately	Who joins within 15 min	Who joins within 1 hour
CRITICAL (fund movement detected)	On-Call Engineer → IC, Forensic Lead, Signers	All signers for affected wallet, Forensic Lead	Communications Lead, Legal Counsel
HIGH (device compromise, no fund movement)	On-Call Engineer → IC, Forensic Lead, Signers	Affected signer + 1 additional signer	Communications Lead
MEDIUM (vendor advisory, anomaly)	On-Call Engineer → IC	Forensic Lead	As determined by IC



5. APPROVED COMMUNICATION CHANNELS

Channel	Use Case	Authentication Method
Signal (Dedicated Group: “IkonPay KCP”)	Primary incident coordination	Verified phone numbers, Safety Numbers confirmed monthly
Phone call (direct dial)	Signer assembly, IC escalation, identity verification	Voice recognition + pre-shared verification phrase
Corporate email (encrypted)	Non-urgent updates, post-incident documentation	PGP-signed emails between custody personnel
In-person (Pune Office)	Signing ceremonies, evidence review	Physical presence verification

Channels Explicitly NOT Approved for KCP

Channel	Reason
Telegram	Unverified identity, message forgery risk (ref: IkonPay Scenario 12 — OTC deal social engineering)
Slack	Corporate channel, potentially compromised during infrastructure breach
SMS	SIM-swap vulnerability
WhatsApp	Insufficient identity verification for high-stakes decisions
Any other informal messaging application not explicitly mentioned in the list of approved communications.	Unreliable communications on informal channels.

Identity Verification Protocol

During a KCP event, before any signer acts on instructions received through any channel:

1. **Verify the caller’s identity** using the pre-shared verification phrase (rotated quarterly, stored offline)
2. **Confirm the instruction via a second approved channel** (e.g., receive instruction via Signal, confirm via phone call)
3. **If identity cannot be verified**, treat the communication as a potential social engineering attack. Escalate to IC and log the potential attempt.

6. RESPONSE PROCEDURES AND KEY MATERIAL CLASSIFICATION

6.1 Response Track A: Hot Wallet Key Compromise (CRITICAL)

Applies to: KM-HOT-BTC-01, KM-HOT-EVM-01, KM-HSM-API

Time Sensitivity: Minutes. Single-signer means full wallet control with compromised key.

Detection Phase (T+0 to T+15)

Step	Action	Responsible	Deadline
A-1	On-chain monitoring alert triggers (unexpected outbound transaction, unknown destination)	Automated system	T+0
A-2	On-call engineer confirms transaction is not in the approval queue	On-Call Engineer	T+5
A-3	If confirmed unauthorised: HALT the Signer Service immediately using the kill-switch mechanism.	On-Call Engineer	T+8
A-4	Page the Incident Commander via phone call	On-Call Engineer	T+10
A-5	IC declares KCP active, activates Signal group "IkonPay KCP"	Incident Commander	T+15

Kill Switch Location:

1. AWS Console → IAM → Roles → [signer-service-prod's task role] → Revoke active sessions
2. AWS Console → ECS → PROD-CUSTODY cluster → Stop task signer-service-prod

On-call engineer has IAM permissions for both actions.

Containment Phase (T+15 to T+90)

Step	Action	Responsible	Deadline
A-6	Assess remaining hot wallet balance (BTC and EVM)	On-Call Engineer	T+20
A-7	Initiate emergency sweep of remaining hot wallet funds to warm wallet rescue address	IC authorises; On-Call Engineer executes via backup signing path	T+30

A-8	Rotate all HSM API credentials (svc-signer-prod service principal)	IC authorises, On-call Engineer executes	T+45
A-9	Revoke and reissue mTLS certificates for Signer-to-CloudHSM communication	On-Call Engineer	T+60
A-10	Assess warm and cold wallet status — verify no unauthorised activity	Forensic Lead	T+90

Eradication Phase (T+90 to T+180)

Step	Action	Responsible
A-11	Determine root cause: API key leak, infrastructure breach, insider, supply chain?	Forensic Lead
A-12	If CloudHSM compromise: engage AWS support to determine whether key material was extractable from the HSM boundary. Follow remediation guidance specific to the advisory.	On-Call Engineer
A-13	Generate new hot wallet keys within CloudHSM (new key ceremony per IP-STD-02)	On-Call Engineer, witnessed by CISO
A-14	Full credential rotation for all systems that share access patterns with the signing service	On-Call Engineer

Recovery Phase (T+180 to T+270)

Step	Action	Responsible
A-15	Deploy new Signer Service with signed container image and new keys	On-Call Engineer
A-16	Configure new hot wallet addresses in Settlement API and Policy/Limit Engine	On-Call Engineer
A-17	Transfer operational funds from warm wallet to new hot wallet (within 5% cap)	Warm wallet signers (2-of-3)
A-18	Verify new hot wallet operations in staging before production activation	On-Call Engineer + IC
A-19	Resume automated merchant payouts	IC authorises

Post-Incident (T+270+)

Step	Action	Responsible
A-20	Notify affected merchants if settlement delays occurred	Communications Lead
A-21	File regulatory notifications per jurisdiction requirements	Legal Counsel
A-22	Initiate insurance claim process (if applicable)	Communications Lead + Legal
A-23	Complete After-Action Report	Forensic Lead
A-24	Update KCP based on lessons learned	CISO

6.2 Response Track B: Warm Wallet — Single Key Share Compromise (HIGH)

Applies to: Compromise of any one of KM-WARM-01, KM-WARM-02, or KM-WARM-03

Time Sensitivity: Hours. 2-of-3 threshold protects funds, but attacker holds 1 share and may be pursuing a second.

Detection Phase

Step	Action	Responsible	Deadline
B-1	Trigger event identified (device loss/theft, tamper seal broken, signer self-report, malware detection on signer device)	Any team member	T+0
B-2	Notify IC via approved channel	Reporting party	T+10
B-3	IC assesses urgency: is there evidence the attacker is pursuing a second share?	IC	T+20

Containment Phase

Step	Action	Responsible	Deadline
B-4	If evidence of multi-share pursuit: Escalate to Track D (At/Above Threshold). Initiate emergency sweep.	IC	Immediate

B-5	If single-share only: Isolate the compromised signer's device. Revoke all access associated with the compromised signer.	Forensic Lead	T+30
B-6	Assess all other access the compromised signer held (monitoring dashboard, infrastructure, backup locations)	Forensic Lead	T+60
B-7	Instruct remaining 2 signers to verify their devices are secure (physical check, offline firmware verification)	IC	T+45

Eradication Phase

Step	Action	Responsible	Deadline
B-8	Procure new Ledger Nano X from verified Ledger-affiliated store	Security Officer	T+24 hours
B-9	Schedule key rotation ceremony: new signer generates key on new device, following IP-STD-02 checklist	CISO coordinates	T+48 hours
B-10	Execute key ceremony with independent firmware verification (manual hash comparison per IP-POL-01)	New signer + ceremony witness	Per ceremony schedule
B-11	Migrate funds to a new Safe incorporating the new key share	All 3 warm signers (2-of-3 from current + new signer joins new config)	Per ceremony schedule

Recovery Phase

Step	Action	Responsible
B-12	Update IP-INV-05 (Key Inventory) with new key share details	CISO
B-13	Update configurations to reflect the new wallet address.	On-Call Engineer
B-14	Verify new multisig configuration with test transaction	Warm wallet signers
B-15	Securely dispose of compromised device per NIST SP 800-88 (CCSS Req 1.06)	Forensic Lead

6.3 Response Track C: Cold Wallet — Single Key Share Compromise (HIGH)

Applies to: Compromise of any one of KM-COLD-01, KM-COLD-02, or KM-COLD-03

Procedure mirrors Track B with the following differences:

- **Signers:** Co-Founders instead of treasury operators
- **Ceremony location:** Bank locker visit may be required for the device stored off-site
- **Fund movement:** Cold wallet holds longer-term reserves — migration involves larger fund volumes
- **Approval authority:** IC + at least one additional Co-Founder must authorise emergency cold wallet sweep
- **Time sensitivity:** Higher than a warm wallet since it holds maximum funds. Urgency increases if attacker may pursue second share

Additional cold wallet consideration: If the compromised device is the one designated for bank locker storage, the bank locker access procedure must be followed.

6.4 Response Track D: Multisig Threshold Breach — At/Above Signing Threshold (CRITICAL)

Applies to: 2 or more of 3 key shares compromised for warm OR cold wallet

Time Sensitivity: Minutes. Attacker can unilaterally move funds.

Step	Action	Responsible	Deadline
D-1	Detect unauthorised transaction from warm or cold wallet	Automated monitoring	T+0
D-2	IMMEDIATELY attempt counter-sweep with remaining clean key + backup of key shares	Remaining clean signer + IC authorisation	T+10
D-3	If sweep possible (remaining signer + one recovered share meets threshold): execute sweep to pre-designated rescue address	Available signers	T+20
D-4	If sweep NOT possible (attacker controls 2+ shares, remaining 1 share insufficient): contact law enforcement immediately	IC + Legal Counsel	T+15
D-5	Engage blockchain analytics firms for fund tracing	Forensic Lead	T+30

D-6	Preserve all evidence: device images, access logs, CCTV footage, communication records	Forensic Lead	T+60
-----	--	---------------	------

6.5 Response Track E: CloudHSM Logical Compromise

Applies to: HSM firmware vulnerability, API exploitation, or AWS infrastructure breach affecting PROD-CUSTODY VPC

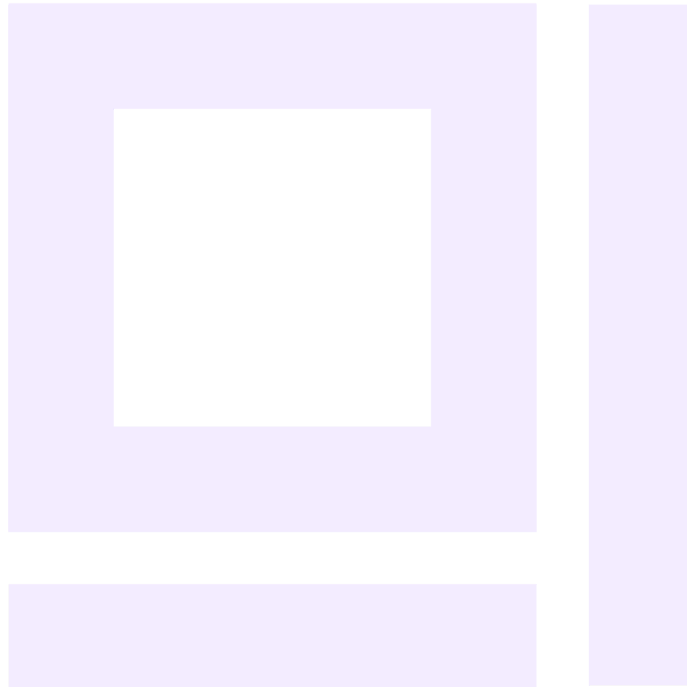
Step	Action	Responsible
E-1	Assess whether the vulnerability allows key extraction from HSM boundary	On-Call Engineer + AWS Support
E-2	Check HSM API access logs for anomalous activity during the exposure window	Forensic Lead
E-3	If key extraction is possible or confirmed: invoke Track A (Hot Wallet Compromise)	IC
E-4	If key extraction is NOT possible but HSM behaviour could be manipulated: halt Signer Service, generate new keys on patched HSM	On-Call Engineer

6.6 Response Track F: Operator Compromise (Duress / Disappearance)

Applies to: Any signer or key holder believed to be under physical duress, coercion, or unexplained disappearance

Step	Action	Responsible
F-1	If signer is unreachable for >24 hours and closest contacts cannot locate them: IC declares operator compromise	IC
F-2	Treat all key material accessible to the compromised operator as potentially compromised	IC
F-3	Do NOT execute any transaction requests from the potentially compromised operator	All signers
F-4	If the operator contacts the team and uses the pre-arranged duress phrase: confirm duress, contact law enforcement	IC

F-5	If the operator contacts the team and does NOT use any verification phrase: treat as potentially compromised communication	IC
F-6	Contact law enforcement — provide operator details, last known location, communication records	IC + Legal Counsel
F-7	Initiate key rotation for all key material the operator held access to	Per Track B or C



7. RESCUE WALLET ADDRESSES

Rescue Wallet	Type	Address	Threshold	Signers
Hot wallet rescue	Warm wallet (existing)	[WARM-WALLET-ADDRESS]	2-of-3	Warm wallet signers
Warm wallet rescue	Cold wallet (existing)	[COLD-WALLET-ADDRESS]	2-of-3	Cold wallet signers
Cold wallet rescue	Pre-designated emergency wallet	[RESCUE-ADDRESS — generated during annual ceremony]	2-of-3	Co-Founders

Rescue wallet addresses to be verified during annual KCP rehearsal. Addresses to be stored in a sealed, tamper-evident envelope in the IC's secure storage and in the bank locker.

8. ESCALATION TIMELINES

Event	Notification Target	Deadline
KCP invoked (any track)	IC	T+10 minutes
Confirmed fund loss	Board of Directors	T+2 hours
Confirmed fund loss > ₹1 Cr	Legal Counsel + Regulatory notification assessment	T+4 hours
Law enforcement involvement needed	IC + Legal Counsel	T+30 minutes from determination
Insurance broker notification	Communications Lead	T+24 hours

9. POST INCIDENT REQUIREMENTS

9.1 After-Action Report (AAR)

Within **7 days** of KCP resolution, the Forensic Lead produces an AAR covering:

- Incident timeline with key decision points
- Root cause analysis
- Blast radius assessment
- Effectiveness of KCP procedures (what worked, what didn't)
- Corrective actions with owners and deadlines
- KCP document updates required
- Recommendations for future prevention

9.2 KCP Updates

Per CCSS v9 Req 2.04.2.1, any improvements identified during a KCP event or rehearsal **must** be incorporated into this document. The CISO is responsible for reviewing and approving all KCP updates. Version history must be maintained.

9.3 Evidence Preservation

During any KCP event, the following evidence must be preserved:

- All communications related to the incident (Signal messages, call logs)
- Device forensic images (before any modification)
- Blockchain transaction records and analytics
- CloudWatch logs, CloudTrail logs, HSM access logs
- CCTV footage from the Pune office and any relevant locations
- Physical evidence (tampered seals, compromised devices)

10. TESTING AND REHERSAL SCHEDULE

Exercise Type	Frequency	Next Scheduled Date	Scope
Full tabletop exercise (externally facilitated)	Annual	[DATE — within 12 months]	All response tracks
Micro-exercise: signer assembly drill	Quarterly	[DATE]	Communication channels + signer availability
Micro-exercise: backup recovery dry-run	Quarterly	[DATE]	Backup access + hardware compatibility
Micro-exercise: hot wallet kill switch test	Quarterly	[DATE]	Signer Service halt + sweep
Trigger-based test	Upon material change	As needed	Changed component

Per CCSS v9 Req 2.04.2.1, testing must also occur whenever there is a material change to people, processes, or technology affecting the custody system.

11. DOCUMENT CONTROL

Version	Date	Author	Changes	Approved By
v1.0	[DATE]	Security Officer(Carol)	Initial KCP document	CISO (Dave)

12. DISTRIBUTION LIST

Role	Access Level
CISO	Full document
All signers (warm + cold)	Sections 1–7 relevant to their classification
On-Call Engineer	Sections 1–6.1, 6.5
Communications Lead	Sections 1–5, 8
Legal Counsel	Sections 1–5, 8, 9
Board of Directors	Executive summary (Section 1 + escalation timelines)